



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

数据驱动的工业互联网自适应防护框架

陶耀东

博士 研究员
360网神沈阳研发中心 总经理



中国互联网络安全大会



360互联网安全中心

目录

工业互联网的架构与安全挑战？

常见应对策略与局限

最新趋势

数据驱动的工业互联网自适应防护架构

360在工业互联网的安全实践



中国互联网络安全大会



360互联网安全中心

工业互联网的架构与安全挑战？

设备、网络、控制、应用、数据、人员、APT

工业互联网——信息化与工业化融合的基础

工业互联网

是互联网和新一代信息技术与工业系统全方位深度融合所形成的产业和应用生态，是提升工业系统**智能化能力的关键信息基础设施**。



工业互联网



工业 4.0



互联网+

Internet + IoT + Cloud + BigData => Cyber-Physical-System (CPS)

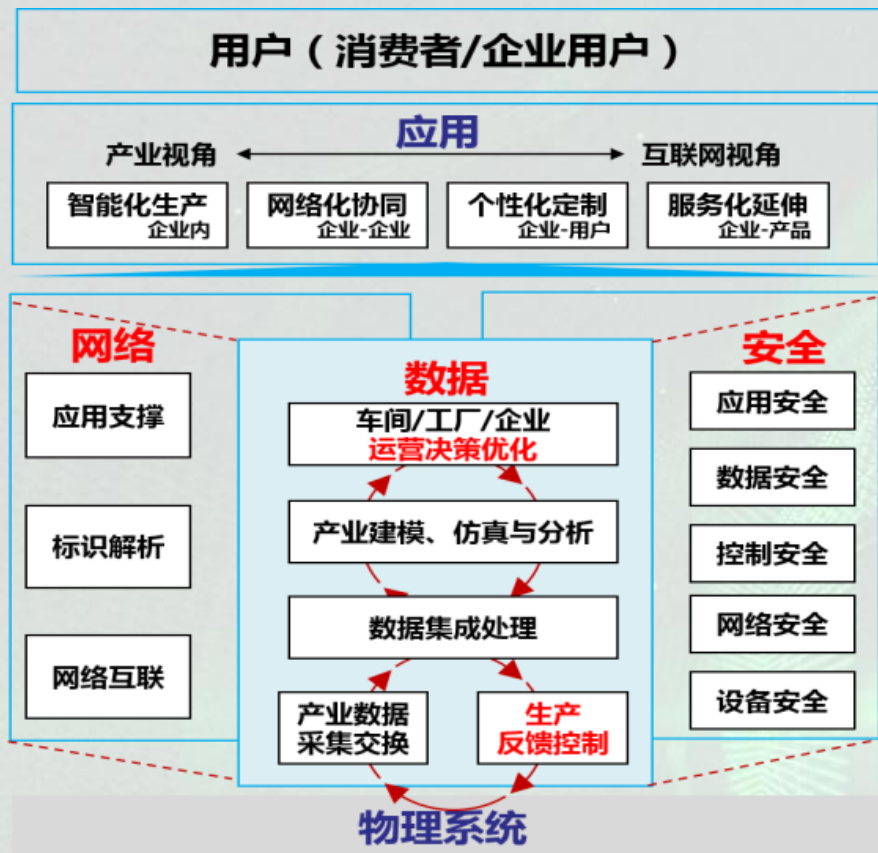
工业互联网典型组成



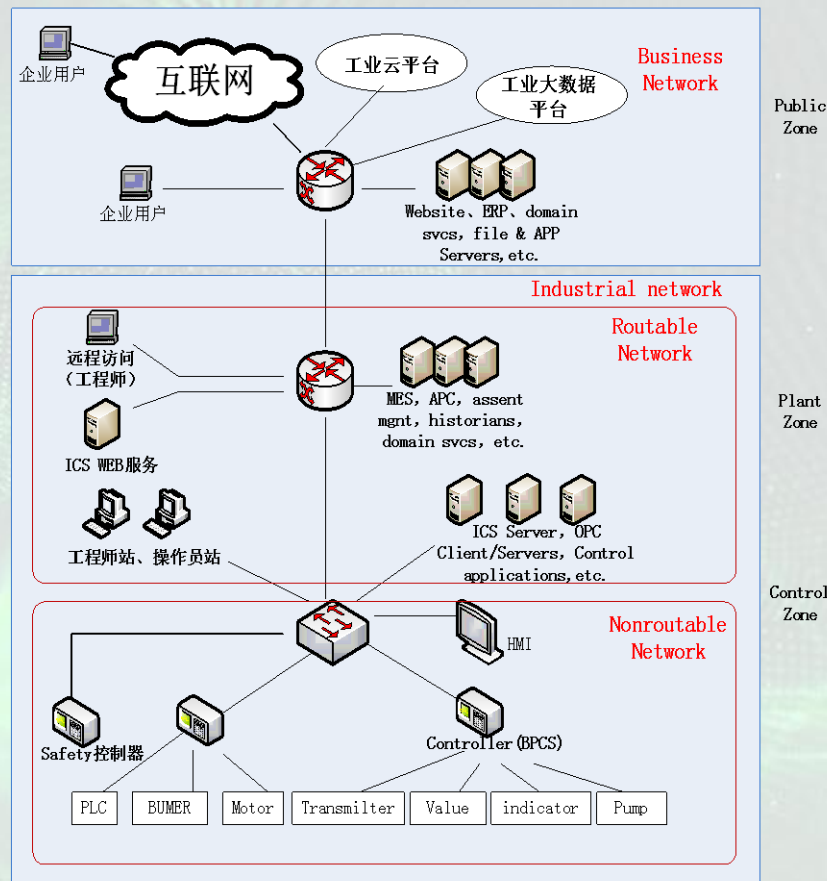
中国网络安全大会



360互联网安全中心



工业互联网体系架构 (AII)



工业互联网典型组成

工业互联网 = 商业网络 + 工业网络

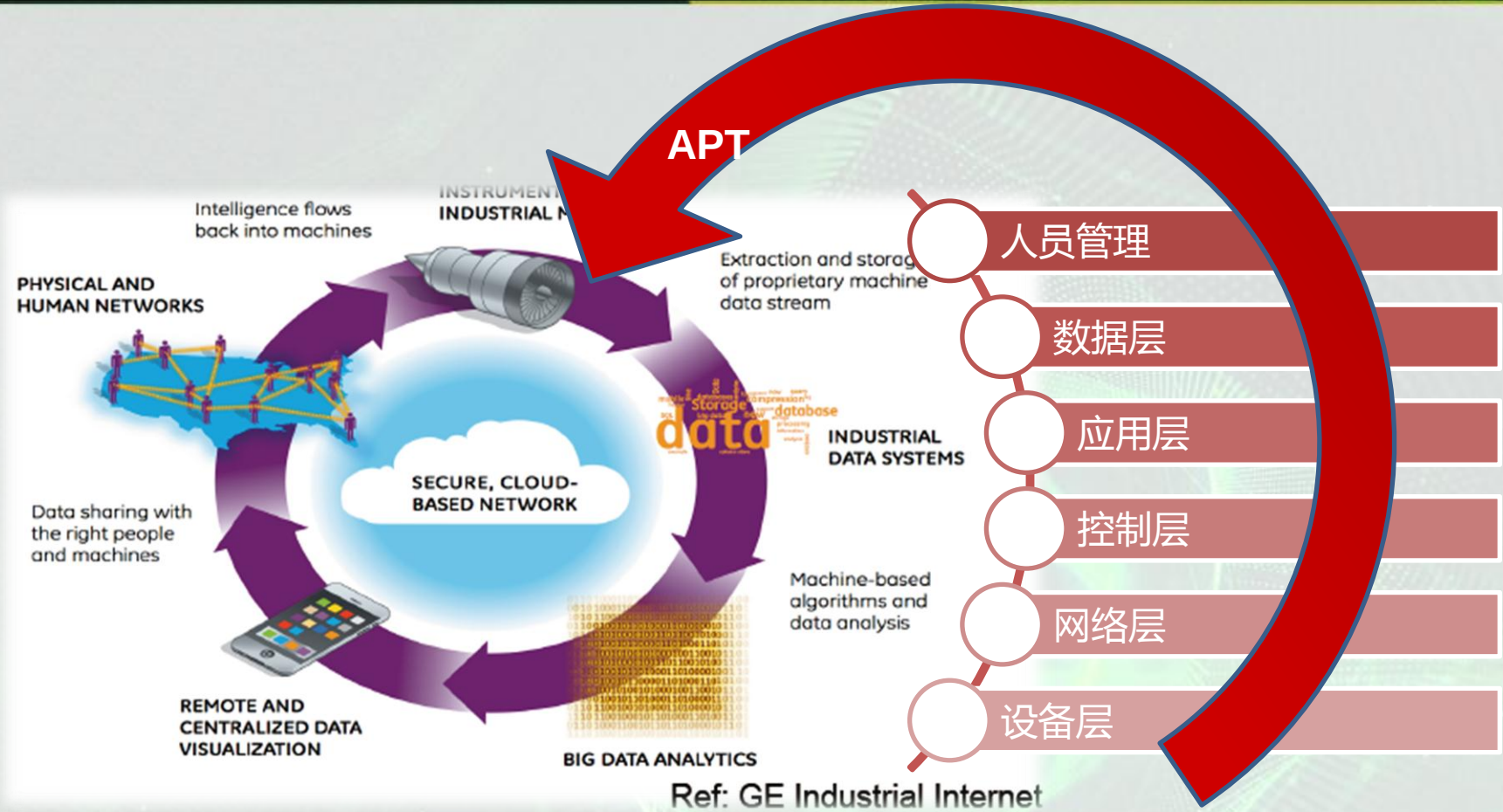
工业互联网的架构与安全挑战



中国互联网络安全大会



360互联网安全中心



攻击入口多、防御剖面大!



中国互联网络安全大会



360互联网安全中心

常见应对策略与局限

工业互联网安全的常用应对措施



中国互联网安全大会



360互联网安全中心

1. 终端防御（审计、白名单等）

2. 纵深防御

- 安全分区、网络专用
- 横向隔离、纵向认证
- 蜜罐等

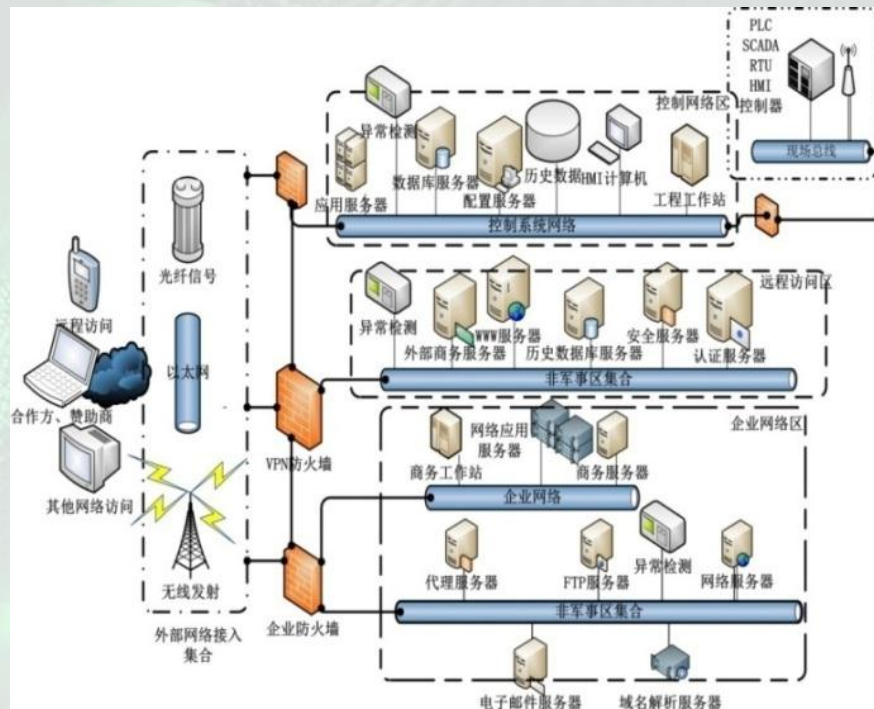
3. 边界防御

- 工业防火墙、网闸等

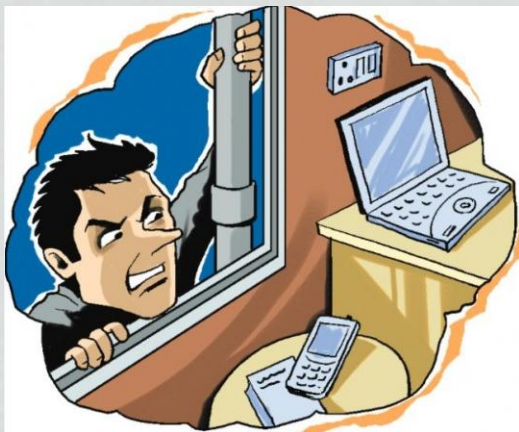
4. 安全远程访问（VPN等）

5. 漏洞和补丁管理

- 漏洞扫描
- 部分补丁



ICS深度防御架构 (NIST SP 800-82 , IEC62443)



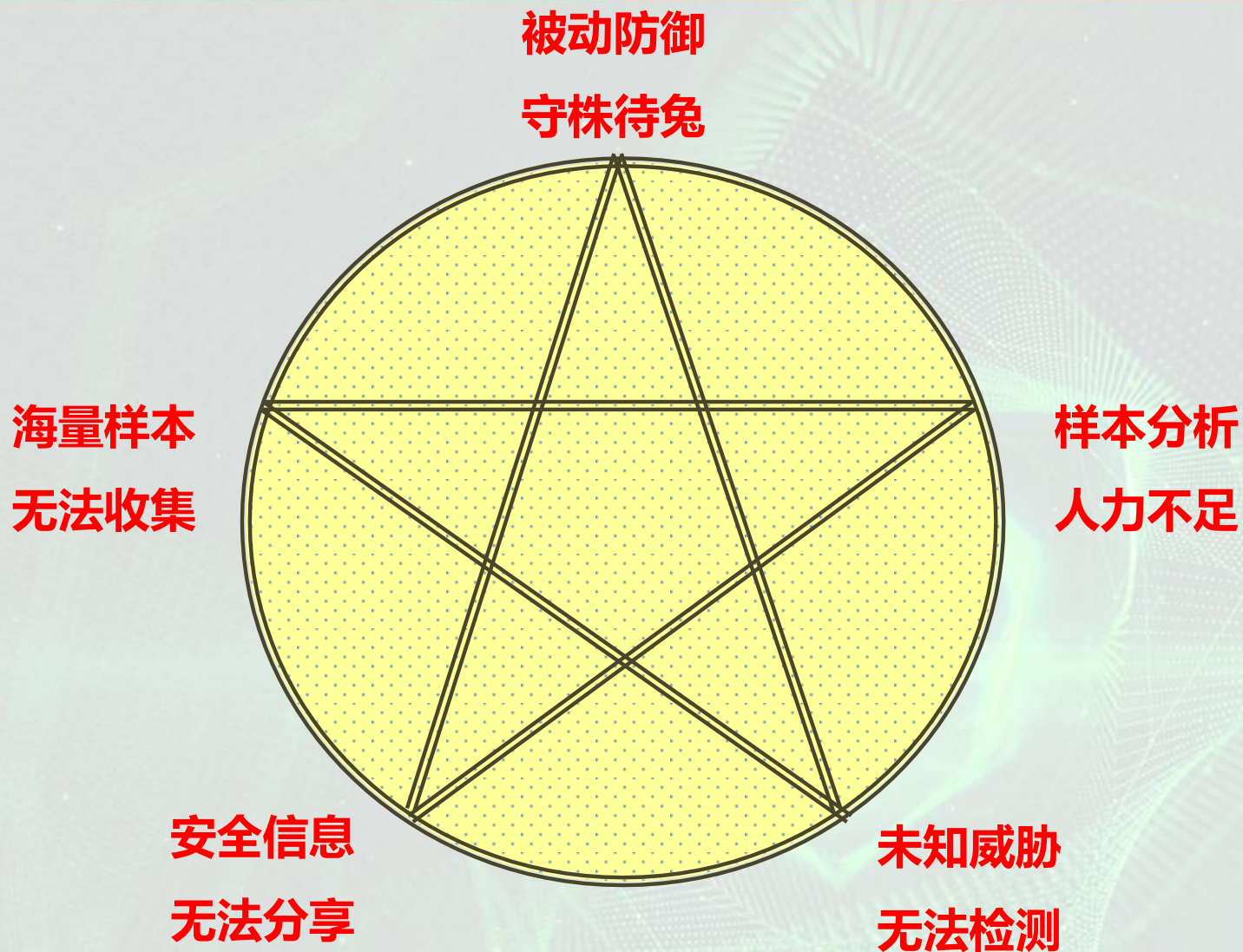
民用攻击：入室行窃，目的是钱
碰运气

高级攻击：宝石大盗，
目的是情报、破坏
不达结果誓不罢休



攻击特点：Oday漏洞、免杀、首次出现、难以检测、长期

常用防御的局限性





中国互联网络安全大会



360互联网安全中心

工业互联网安全的最新趋势

应急响应 => 持续监测响应

- 持续监测收集信息
- 增强检测和响应能力

数据驱动安全

- 态势感知
- 威胁情报
- 威胁追踪溯源

建立企业安全运维中心(SOC)

- 工业大数据异常发现
- 用户与实体行为分析 (UEBA)

产业协同：联合防御

- 供应链安全
- 安全即服务



攻击特点

外链URL

恶意IP

恶意域名

样本MD5

云端

攻击背景





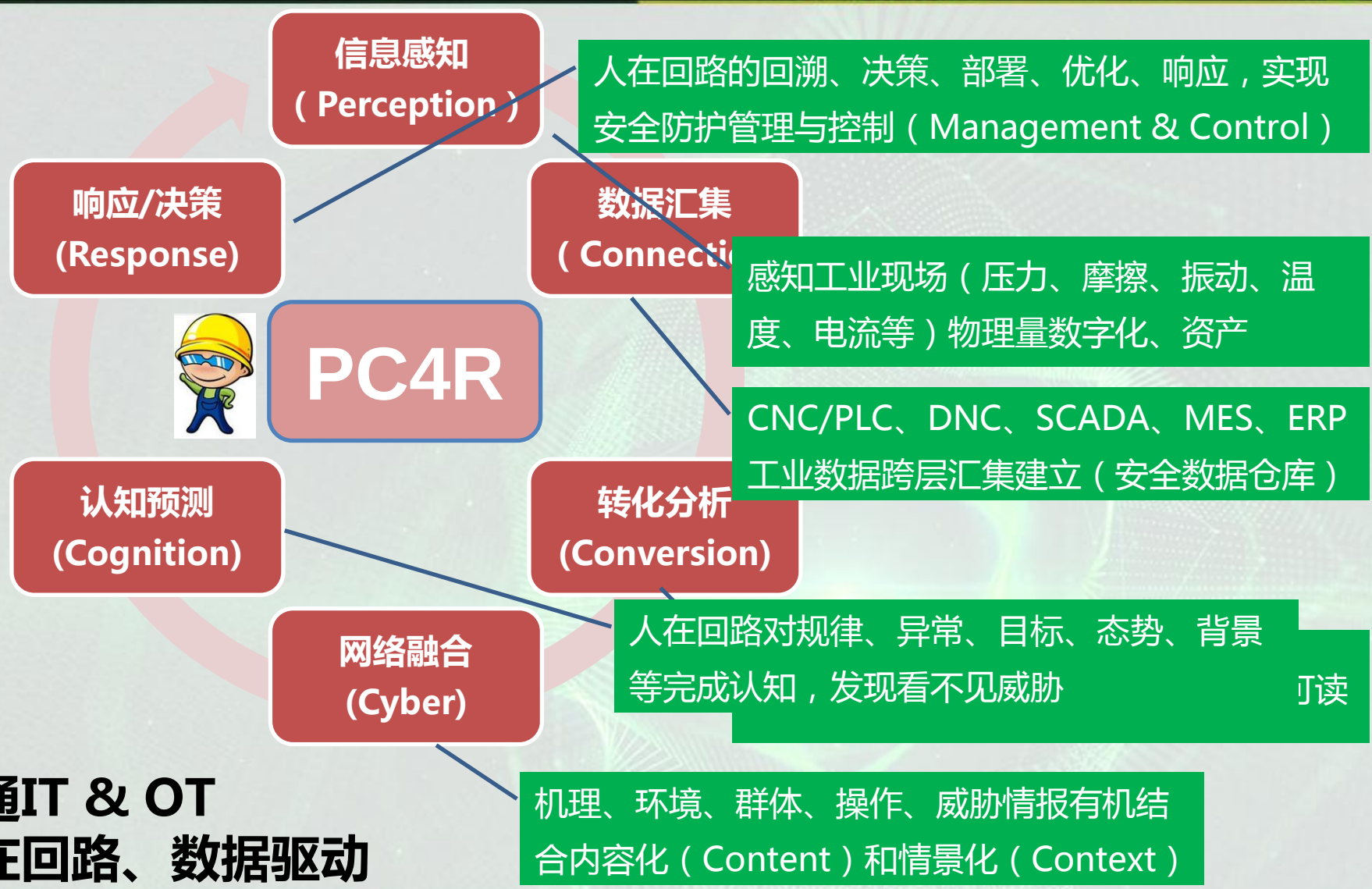
中国网络安全大会



360互联网安全中心

数据驱动自适应防护架构

工业互联网自适应防护架构（PC4R）

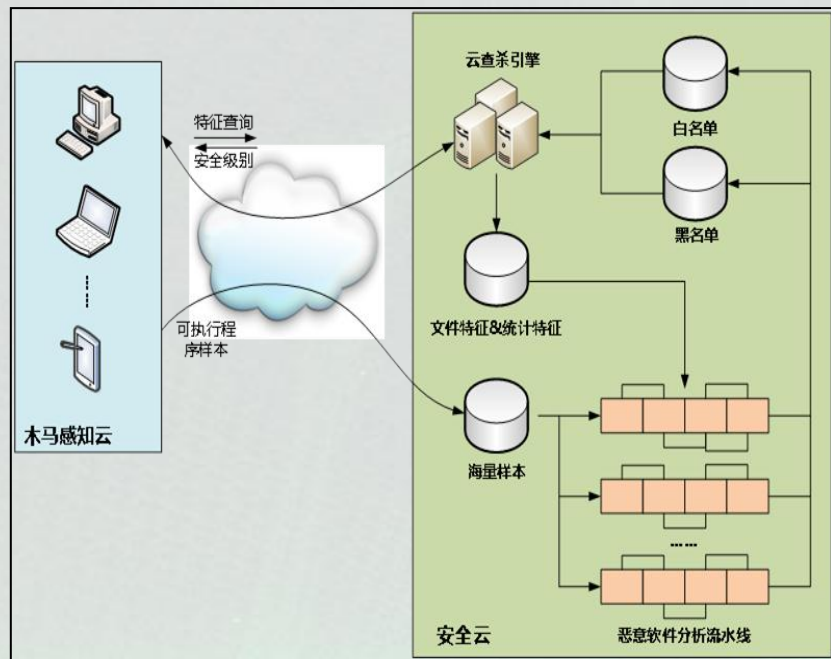


打通IT & OT
人在回路、数据驱动

防御技术路线：大数据发现威胁情报

目标

通过云端大数据关联与挖掘，发现威胁情报，包含域名、IP、木马、MD5等



运营全球最大云安全系统

技术特点

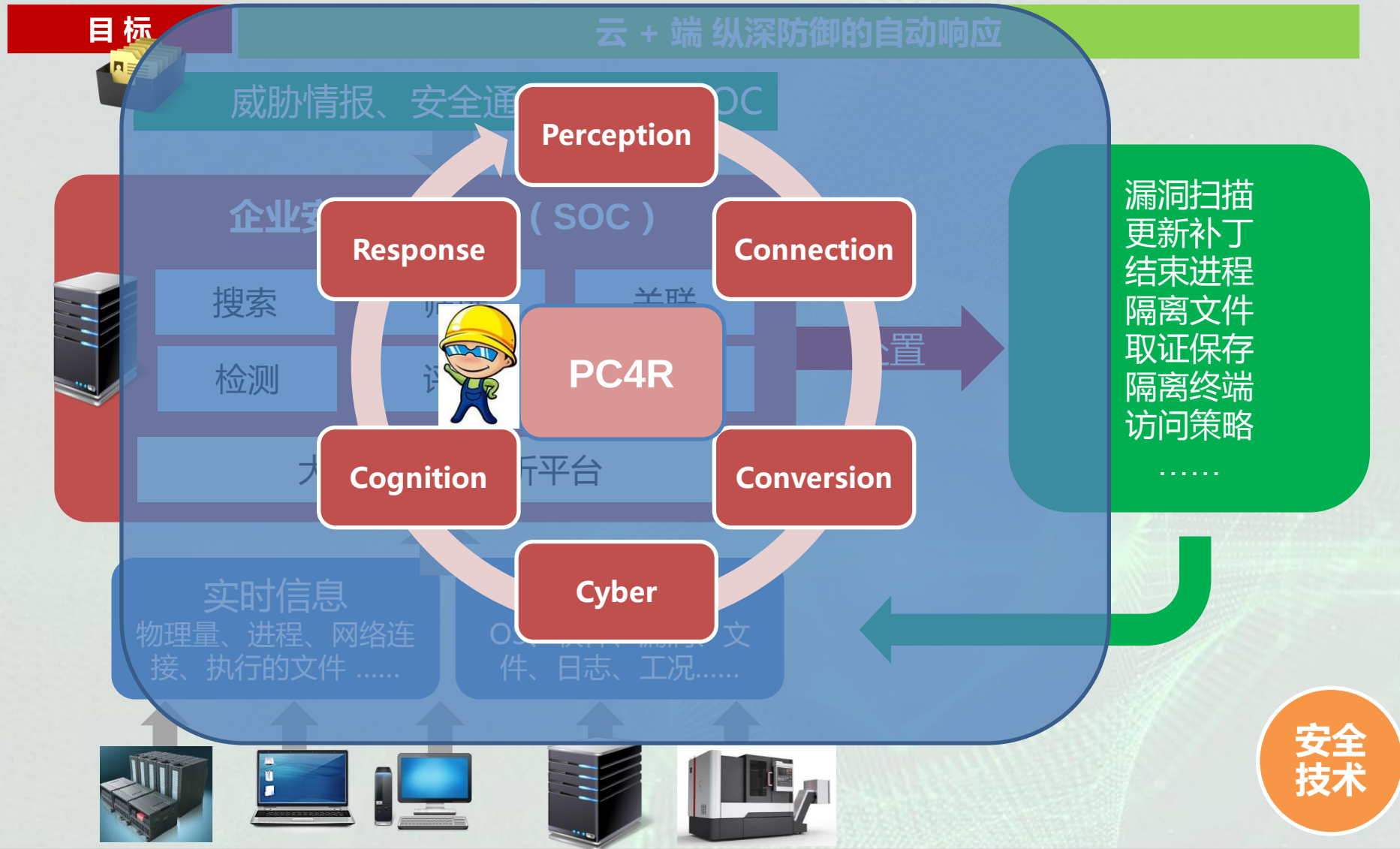
- 2万台云安全服务器，每日2000亿次查询
- 总存储数据量200PB+，每天新增1PB
- 每天计算任务20000个，每天计算处理数据3.5PB
- 每日发现近80万种，600万个木马，覆盖5亿PC用户和6亿手机用户

2016年3月，率先披露了长期对亚洲国家的能源、交通等基础行业进行网络渗透和情报窃取的APT组织——“洋葱狗”（OnionDog）

2016年8月，APT组织“索伦之眼”Sauron，针对水利、海洋行业，综合能力不弱于震网（Stuxnet），**攻击能力和技术水准最高的一个**

威胁情报

防御技术路线：建立企业本地安全运维中心



防御技术路线：构建工控系统安全白环境

目标

基于大数据，构筑工业互联网系统“安全白环境”整体防护体系

- 持续监控收集，实时探测，云端判断、取证、溯源、修复；
- 被动解决方案，不影响工控系统的“可用性”和“稳定性”
- 工控协议深度解析技术，具备高安全性，低时延影响；

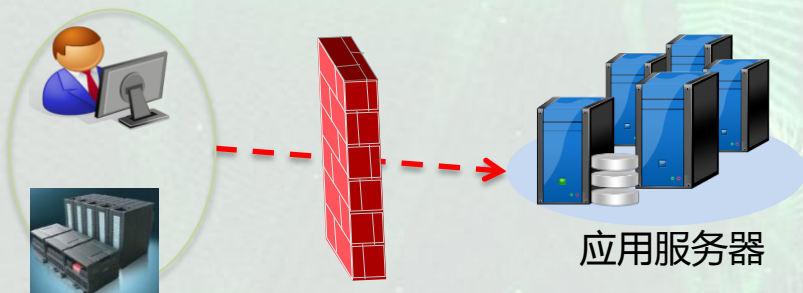
收集数据

构建白名单

云端+本地，获得“可信网络白环境”和“工业互联网软件白名单”

- 可信任的设备才能接入控制网络
- 可信任的信息才能在网络上传输
- 可信任的软件才允许被执行

安全技术



系统进程



应用进程



恶意进程



目标

安全是一种可以采购的服务

安全咨询与运维服务	信息安全咨询服务
	安全技术服务
	本地安全运维服务
	技术专家应急响应服务
网络安全监测预警服务（面）	大数据网络安全监测预警平台基础服务
网站与应用安全运行监测预警服务（点）	漏洞监测
	篡改、挂马暗链监测
	网站运维云监控



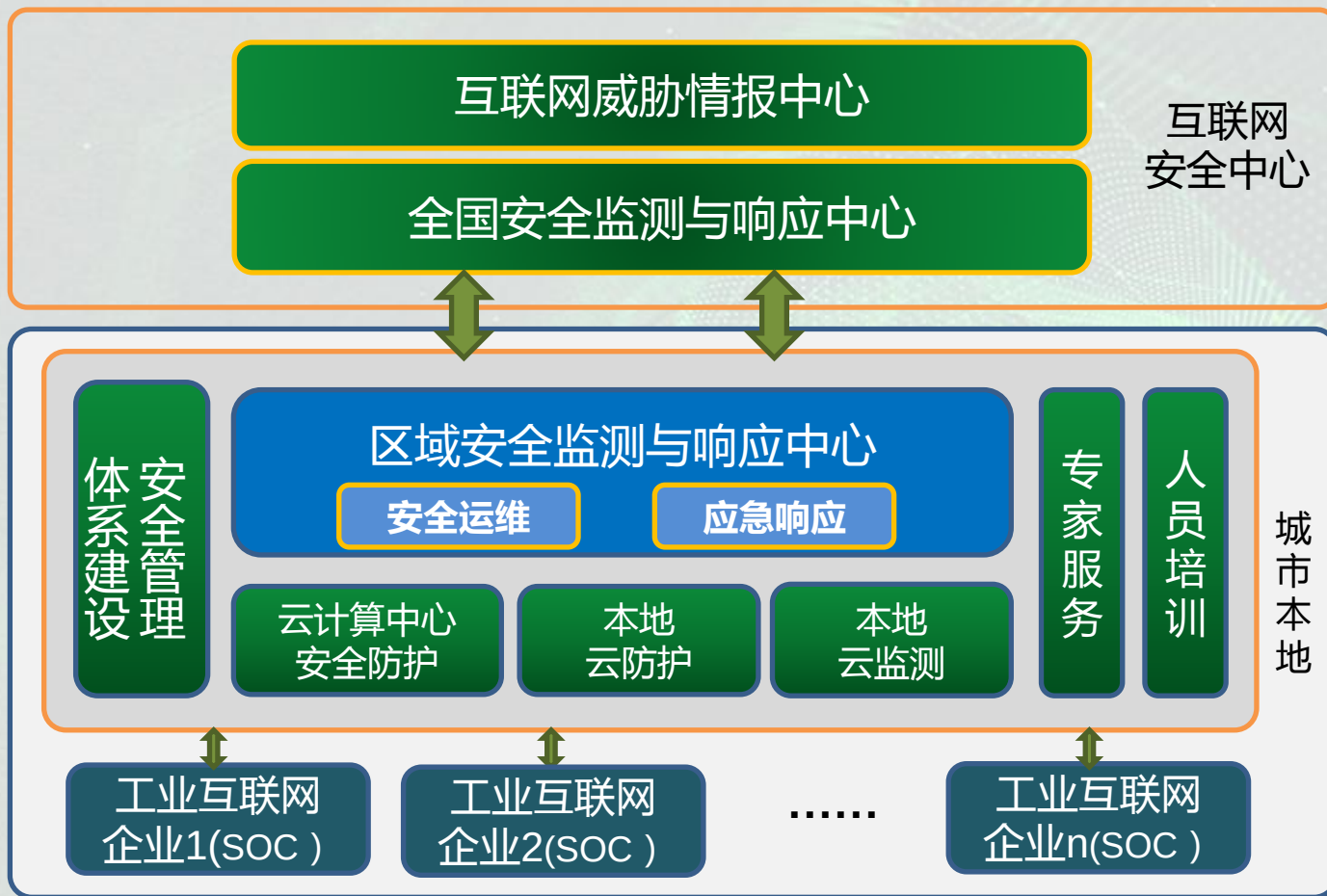
以按需、易扩展的方式获得所需安全服务



防御技术路线：多级安全服务体系

目标

协同防御：构建工业互联网企业安全共同体



安全
服务



数据驱动安全



中国互联网安全大会



360互联网安全中心

360在工业互联网的安全实践

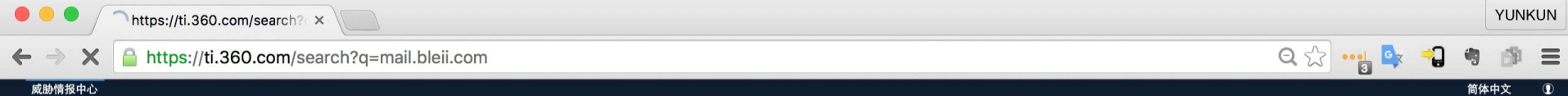
威胁溯源 — 威胁情报中心



中国互联网安全大会

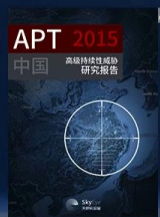


360互联网安全中心



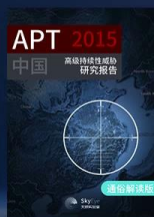
360威胁情报中心

mail.bleii.com



01-15[APT]

2016



02-23[APT]



02-29



待发布



待发布[APT]

Waiting for ti.360.com...

Copyright © 2005-2016 360.CN All Rights Reserved 360安全中心

京公网安备 11000002000006号

可视化分析关联



安全实践：威胁看的见，APT检测



360
SkyEye



中国互联网安全大会



360互联网安全中心

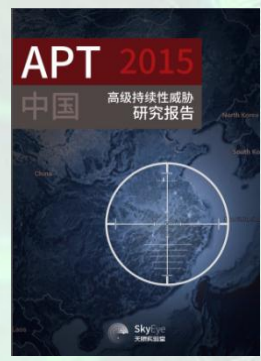
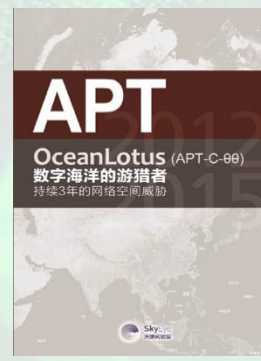


天眼ATP攻击检测防御系统

- 国内率先**运用大数据技术发现未知威胁**的厂商
- 360威胁情报中心**已监测到各类APT攻击事件数万次
- 针对中国境内发动APT的境外组织**29个**，其中**14个**为360首先发现

2016年3月，率先披露了长期对亚洲国家的能源、交通等基础行业进行网络渗透和情报窃取的APT组织——“洋葱狗”（OnionDog）
2016年8月，索伦之眼 Sauron，高度复杂，不亚于stuxnet

APT活动	境内感染量	首次发现时间	最近发现时间	影响省份数	影响行业	感染方式
APT-C-00	1047	2014/2/18	2015/5/22	30	政府、海洋、海事	鱼叉邮件、水坑
APT-C-01	235	2014/2/15	2015/4/5	28	政府	鱼叉邮件
APT-C-04	17	2014/4/3	2014/6/29	3	科研、教育	鱼叉邮件
APT-C-02	180	2014/8/1	2015/4/14	9	教育	鱼叉邮件
APT-C-03	5	2014/11/3	2014/12/15	2	非政府组织	鱼叉邮件
APT-C-05	12	2015/2/12	2015/3/24	3	政府	鱼叉邮件
APT-C-06	4	2015/2/24	2015/3/7	3	科研	鱼叉邮件



安全实践：系统脆弱，360补天



漏洞管理，防微杜渐



帮助企业建立SRC(安全应急响应中心)，早地发现、修补工业系统及相关IT系统的漏洞，最大程度避免工业企业由于安全漏洞遭受损失

补天漏洞响应平台

- 国内权威第三方漏洞收集、安全评估众筹
- 建立一个对各方都有益的企业安全生态系统

拥有国际顶级的系统漏洞研究能力

- 拥有中国一半以上的顶级安全专家，号称东半球最强的白帽子军团
- 拥有漏洞分析、网络攻防、网络安全研究等多个实验室
- 拥有协议与逆向分析、IOS安全、无线安全等8个安全团队



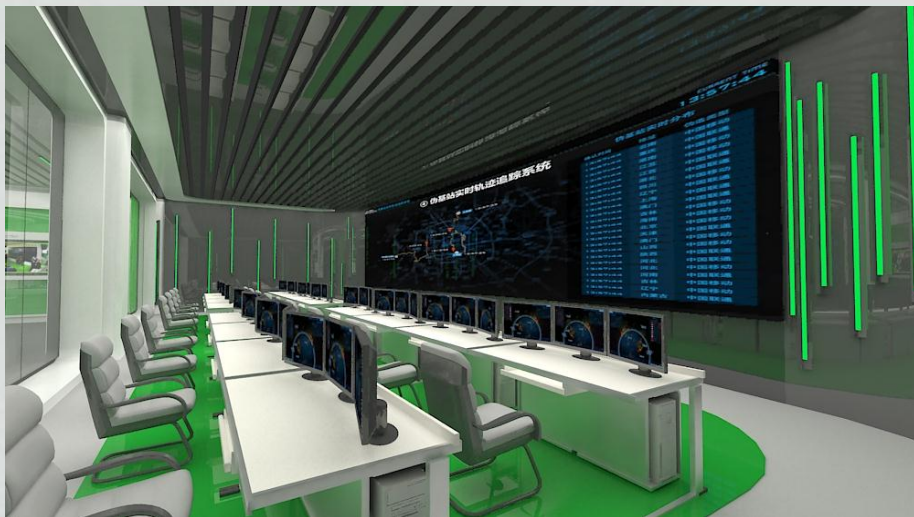
360 多级互联网安全服务中心



中国互联网安全大会



360互联网安全中心

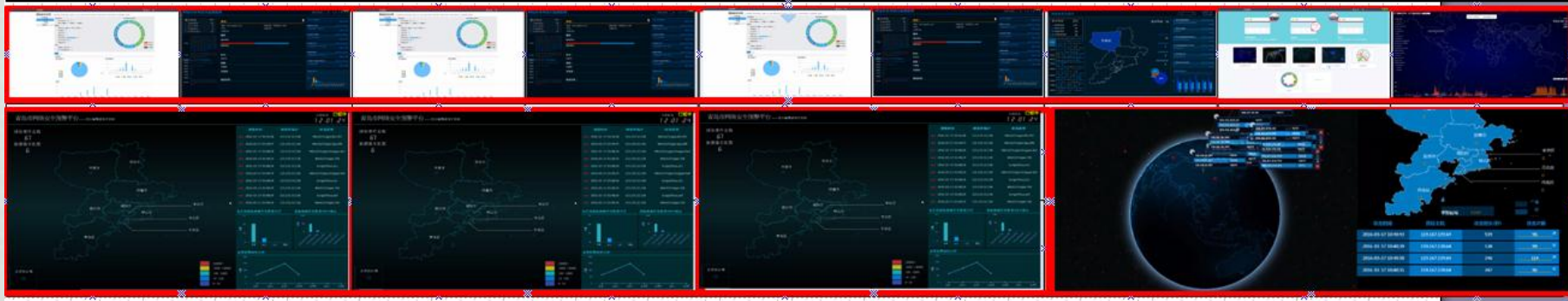


一级安全服务中心（全国）



二级安全服务中心（区域）

360 互联网安全中心（东北中心）



服务中心监控图像（示意图）

安全实践：智能硬件，物联安全、汽车安全



中国互联网安全大会



360互联网安全中心



360UnicornTeam
无线、硬件安全



360 ADLAB

- 智能产品的安全研究
- 车联网的安全研究



360安全联盟 (360safe.com)

谢 谢



中国互联网络安全大会



360互联网安全中心

谢 谢



中国互联网络安全大会



360互联网安全中心

谢 谢



中国互联网络安全大会



360互联网安全中心

谢 谢



中国互联网络安全大会



360互联网安全中心

谢 谢



中国互联网络安全大会



360互联网安全中心